

## SÍNTESIS EJECUTIVA: KIT COMPLETO ENCUESTA CIBERSEGURIDAD 7 DOCUMENTOS

### Resumen Integral + Flujo de Implementación

**Versión:** 1.0 | **Fecha:** Enero 2026

**Total Documentos:** 7 archivos .md profesionales

**Total Contenido:** ~240 páginas guía exhaustiva

**Público:** Ejecutivos, CISOs, Risk Managers, Analistas

**Contexto:** España/EU (NIS2, ISO 27001, GDPR)

### PROPÓSITO GENERAL DEL KIT

Proporcionar **framework integral, operacional y regulatorio** para evaluar madurez ciberseguridad de organizaciones españolas en 7 módulos (51 preguntas), alineado con:

-  Regulaciones: NIS2 (Aug 2026), ISO 27001, GDPR, Plan Nacional
-  Metodología: GQM (Goal-Question-Metric) + 5-level maturity
-  Aplicabilidad: 7 módulos holísticos (gobernanza + técnico + compliance + cultura)
-  Implementación: Roadmap 4 fases, presupuesto €2.1M, ROI 180%

### LOS 7 DOCUMENTOS: DESCRIPCIÓN Y FLOW

#### DOCUMENTO 1: Modelo de Encuesta Integral

**Archivo:** modelo\_encuesta\_integral\_es.md

**Tamaño:** ~30 páginas

**Propósito:** Cuestionario estructurado

### Contenido:

- 7 Módulos, 51 preguntas totales:

- 

#### Gobernanza & Liderazgo (5 preguntas)

Estado función ciberseguridad

Revisión estrategia con liderazgo

Política documentada y comunicada

Alineación presupuesto

% IT budget destinado

- 

#### Gestión Vulnerabilidades (9 preguntas)

Madurez programa VM

% SLA compliance

Integración threat intelligence

Frecuencia pen testing

MTTR vulnerabilidades críticas

Metodología testing

Retest post-remediation

% apps evaluadas

Scope testing elements

- 

#### SIEM & Detección (10 preguntas)

Existencia SIEM solution

Log sources integradas

Capacidad retención logs

Tipos alertas implementadas

Volumen eventos procesados

False positive rate

Integración SIEM-SOAR

Threat hunts ejecutadas

Frameworks cubiertos

Frecuencia reportería

- - Acceso e Identidad (3 preguntas)  
  
Sistema gestión identidades  
MFA implementation  
PAM program existence
- - Capacitación & Conciencia (8 preguntas)  
  
Tipos capacitación ofrecida  
Frecuencia obligatoria  
% completación  
Medición resultados  
Phishing simulation results  
Comunicación a ejecutivos  
Enfoques engagement  
Tópicos cubiertos
- - Respuesta a Incidentes (7 preguntas)  
  
Plan IR formalizado  
Playbooks documentadas  
Frecuencia testing  
Tiempo MTTR promedio  
Integración con otros sistemas  
Post-incident review  
Threat intel integration

- Estrategia Integrada (9 preguntas)  
  
Estrategia documentada  
Alineación con negocio  
Roadmap 3-year  
Governance framework  
Métricas clave definidas  
Reporting cadence  
Risk appetite statement  
Resource allocation  
Continuous improvement process
- Formato: Preguntas cerradas + abiertas (mix)
- Escala: Levels 0-5 (Inicial → Optimizado)
- Tiempo: 60-75 min por entrevista

### **Gobernanza & Liderazgo** (5 preguntas)

- Estado función ciberseguridad
- Revisión estrategia con liderazgo
- Política documentada y comunicada
- Alineación presupuesto
- % IT budget destinado

### **Gestión Vulnerabilidades** (9 preguntas)

- Madurez programa VM
- % SLA compliance
- Integración threat intelligence
- Frecuencia pen testing
- MTTR vulnerabilidades críticas
- Metodología testing
- Retest post-remediation
- % apps evaluadas
- Scope testing elements

### **SIEM & Detección** (10 preguntas)

- Existencia SIEM solution
- Log sources integradas
- Capacidad retención logs
- Tipos alertas implementadas
- Volumen eventos procesados
- False positive rate
- Integración SIEM-SOAR
- Threat hunts ejecutadas
- Frameworks cubiertos
- Frecuencia reportaría

#### **Acceso e Identidad (3 preguntas)**

- Sistema gestión identidades
- MFA implementation
- PAM program existence

#### **Capacitación & Conciencia (8 preguntas)**

- Tipos capacitación ofrecida
- Frecuencia obligatoria
- % completación
- Medición resultados
- Phishing simulation results
- Comunicación a ejecutivos
- Enfoques engagement
- Tópicos cubiertos

#### **Respuesta a Incidentes (7 preguntas)**

- Plan IR formalizado
- Playbooks documentadas
- Frecuencia testing
- Tiempo MTTR promedio
- Integración con otros sistemas
- Post-incident review
- Threat intel integration

#### **Estrategia Integrada (9 preguntas)**

- Estrategia documentada
- Alineación con negocio
- Roadmap 3-year
- Governance framework
- Métricas clave definidas
- Reporting cadence
- Risk appetite statement
- Resource allocation
- Continuous improvement process

**Formato:** Preguntas cerradas + abiertas (mix)

**Quién lo usa:**

- Facilitador: Administra durante interviews
- Respondentes: CISO, CTO, Risk Head, SOC Lead, etc. (5 stakeholders)
- Analyst: Entra datos en Excel post-interview

**Cuándo se usa:**

- Semana 1: Assessment execution (cuestionario base)
- Validación: Post-interview (confirmar respuestas)

**2 DOCUMENTO 2: Guía Metodológica Detallada**

**Archivo:** guia\_metodologica\_encuesta\_es.md

**Tamaño:** ~25 páginas

**Propósito:** Instrucciones facilitador + scoring criteria

### Contenido:

- Introducción GQM methodology: 4-level hierarchy (Strategic → Tactical → Operational → Metrics)
- Escala madurez 0-5:
- Nivel 0: Inexistente
- Nivel 1: Inicial (ad-hoc)
- Nivel 2: Repetible (process emerging)
- Nivel 3: Definido (formal documented)
- Nivel 4: Gestionado (measured & monitored)
- Nivel 5: Optimizado (continuous improvement)
- Por cada pregunta:
- Scoring guidance (0-5 rubric)
- Examples de respuestas Level 1 vs Level 3 vs Level 5
- Evidence requerida (data sources)
- Red flags (common mistakes)
- Probing questions (para esclarecer)
- Scoring consolidation: Cómo agregar respuestas (promedio vs weighted)
- Validation techniques: Cómo resolver divergencias >15pp
- Quality assurance: Checks post-assessment

Nivel 5: Optimizado (continuous improvement)

### Por cada pregunta:

Probing questions (para esclarecer)

**Scoring consolidation:** Cómo agregar respuestas (promedio vs weighted)

### Quién lo usa:

- Facilitador: Referencia durante interviews (scoring criteria)
- Analyst: Para validación/consolidation post-interviews
- CISO: Para entender escala interpretación

### Cuándo se usa:

- Pre-assessment: Facilitador training (1-2 horas)
- During: Consulta scoring criteria
- Post: Validación scoring antes consolidación

### 3 DOCUMENTO 3: Narrativa Explicativa

**Archivo:** narrativa\_explicativa\_encuesta\_es.md

**Tamaño:** ~20 páginas

**Propósito:** Background + justificación framework

#### Contenido:

- ¿Por qué este assessment? Regulatory drivers (NIS2 Aug 2026), financial case, strategic alignment
- ¿Por qué 7 módulos? Holistic coverage rationale:
- Mod 1: Governance (enables all others)
- Mod 2-3: Detection (find problems)
- Mod 4: Access (prevent unauthorized)
- Mod 5: Culture (human security)
- Mod 6: Response (react when needed)
- Mod 7: Strategy (orchestrate all)
- ¿Por qué GQM? Methodological rigor, traceability, maturity calibration
- Alineación regulatoria: NIS2 articles mapped to modules
- Industria contexto: Benchmark data (average scores Spain vs EU)
- Investment case: €2.1M investment, 180% 3-year ROI
- Timeline: 18-month roadmap, 4 phases
- Success stories: Brief case studies (anonymized)

Mod 7: Strategy (orchestrate all)

**¿Por qué GQM?** Methodological rigor, traceability, maturity calibration

#### Quién lo usa:

- CISO: Para executive briefing (contexto)
- Board/Leadership: Para entender "why now"
- Stakeholders: Para buy-in/alignment

#### Cuándo se usa:

- Pre-kick: Stakeholder briefing (10-15 min read)
- Executive education: Explicar strategic importance

### 4 DOCUMENTO 4: Mapeo Normativo Detallado

**Archivo:** mapeo\_normativo\_encuesta\_es.md

**Tamaño:** ~50 páginas

**Propósito:** Validación compliance + trazabilidad regulatoria

### Contenido:

- Línea-por-línea mapping: Cada pregunta encuesta vs regulaciones:
- NIS2 (Directiva 2022/2555) - Artículos clave (17, 18, 19, 20)
- ISO 27001:2022 - Clauses & Controls (5.1, 6.2, A.9.1, A.16.1.5, etc.)
- GDPR (Regulación 2016/679) - Articles (5, 32, 33, 34)
- Plan Nacional Ciberseguridad - Líneas de acción
- COBIT 2019 - Governance objectives
- Por cada pregunta (51 total), tabla con:
  - Normativa primaria + artículos específicos
  - Plazo cumplimiento (criticidad)
  - Organismo supervisión responsable
  - Mínimo compliance score requerido
  - Penalidades no-cumplimiento
  - Evidencia requerida
- Tabla consolidada resumen: Quick reference (Module × Normativa)
- Sección riesgos: Gap analysis vs regulaciones

COBIT 2019 - Governance objectives

**Por cada pregunta (51 total), tabla con:**

Evidencia requerida

**Tabla consolidada resumen:** Quick reference (Module × Normativa)

### Quién lo usa:

- Compliance Officer: Validación alineación NIS2/ISO
- Risk Manager: Identificación gaps regulatorios + plazos
- CISO: Priorización basada en deadline

### Cuándo se usa:

- Semana 2-3 (Post-assessment): Análisis compliance
- Roadmap planning: Priorizar remediación por deadline
- Ongoing: Referencia regulatory requirements

### *Aplicación Clave:*

- NIS2 deadline: Aug 31, 2026 (11 meses) – CRÍTICO
- ISO audit: Q4 2026 – importante
- GDPR: Ongoing – baseline requirement

### **5** DOCUMENTO 5: Plantilla Excel IMC+ROI

**Archivo:** plantilla\_excel\_imc\_roi\_encuesta\_es.md

**Tamaño:** ~25 páginas (instrucciones)

**Propósito:** Cálculos automáticos madurez + financiero

### *Contenido:*

**Estructura 5 hojas Excel:**

1. Dashboard (Executive View):
2. 7 módulos: Score, Level, Compliance%, Implementation%, IMC
3. Status indicators (●●●)
4. Portfolio IMC promedio
5. Compliance metrics consolidated
6. Regulatory readiness heatmap
7. Module Detail (7 hojas, 1 por módulo):
8. Preguntas desglosadas
9. Individual scores
10. PRAGMATIC-style criteria (Predictive, Relevant, Actionable, etc.)
11. Fortalezas/gaps por módulo
12. Recomendaciones
13. Costs & ROI:
14. Presupuesto desglosado (€2.1M):
  - Phase 1: €0
  - Phase 2: €1.2M
  - Phase 3: €200K
  - Phase 4: €700K
15. ROI scenarios (Conservative/Realistic/Optimistic)
16. Payback period calculations
17. Sensitivity analysis
18. Trajectory (18-36 meses):
19. Quarter-by-quarter IMC projection
20. Module scores evolution
21. Phase milestones
22. Success criteria 2026-2027

23.

Raw Data Input:

24. Field para entry datos brutos

25. Data sources specification

26. Monthly update sheet

Regulatory readiness heatmap

### **Module Detail (7 hojas, 1 por módulo):**

Recomendaciones

#### **Costs & ROI:**

- Phase 1: €0
- Phase 2: €1.2M
- Phase 3: €200K
- Phase 4: €700K

Sensitivity analysis

#### **Trajectory (18-36 meses):**

Success criteria 2026-2027

#### **Raw Data Input:**

##### **Fórmulas Clave:**

$IMC = (Avg\_Módulos \times 0.50) + (Compliance\% \times 0.30) + (Implementation\% \times 0.20)$

$ROI\% = (Benefits - €2.1M) / €2.1M \times 100$

$Payback \text{ (meses)} = 12 / (Annual\_Benefit/12 / €2.1M)$

##### **Quién lo usa:**

- CFO/Finance: Budget validation, ROI justification
- CISO: Monthly progress tracking
- Board: Financial oversight
- Analyst: Data entry & calculations

##### **Cuándo se usa:**

- Semana 3 (Post-assessment): Data entry
- Monthly: Updates & trending
- Quarterly: Board reporting

## **6** DOCUMENTO 6: Plantilla PowerPoint Reporte Ejecutivo

**Archivo:** plantilla\_powerpoint\_reporte\_encuesta\_es.md

**Tamaño:** ~30 páginas (plantilla + speaker notes)

**Propósito:** Presentación Board & C-level (45 minutos)

### Contenido:

#### 13 Diapositivas Clave:

27. Portada - Contexto, fecha, presentador, confidencialidad
28. Agenda - Timeline 45 min
29. Contexto & Drivers - NIS2 deadline (Aug 2026), regulatory mandate, financial case
30. IMC Snapshot - Current 39/100 (Level 2), vs benchmark, compliance metrics
31. 7 Módulos Scorecard - Heat map, traffic lights, individual scores
32. Top 3 Strengths - Celebrate wins (governance foundation, awareness program, etc.)
33. Top 3 Critical Gaps - Transparency (SIEM, Vuln.Mgmt, Strategy gaps)
34. Regulatory Compliance Heatmap - NIS2/ISO/GDPR readiness por module
35. Implementation Roadmap - 4 fases, Gantt chart, investment timeline
36. Budget & ROI - €2.1M investment breakdown, 3 ROI escenarios, payback analysis
37. Risk If No Action - Do-nothing cost vs invest value
38. Board Decisions - 5 decisiones requeridas (Strategic, Budget, Governance, Risk Appetite, Timeline)
39. Next Steps & Success Metrics - 30-60-90 day roadmap, KPIs end-2026

### Story Arc:

Hook (3 min): "NIS2 deadline Aug 31, 2026; €50M penalty if non-compliant"  
Context (5 min): "We're at 39/100 Level 2; +1pp vs industry but -33pp vs leaders"  
Analysis (12 min): "What's working (governance, training); what's broken (SIEM, VM, strategy)"  
Solution (15 min): "4-phase roadmap; €2.1M investment; 10-month payback"  
Action (5 min): "5 board decisions needed; approval this meeting"  
Q&A (5 min): Responder preguntas  
Total: 45 min

### Visualizaciones:

- Gauge/dial (IMC 39/100)
- Bar charts (comparison vs benchmark)
- Heat maps (compliance by framework)
- Gantt timelines (roadmap phases)
- Waterfall charts (investment → benefits)
- Traffic lights (status indicators)

### Quién lo usa:

- CISO: Presentador principal
- CFO: Financial slides
- Board/CEO: Audiencia; toman decisiones
- Communications: Adaptation para stakeholder updates

### *Cuándo se presenta:*

- Semana 4-5: Board presentation (45 min)
- Monthly: Steering committee updates (versión adaptada)

## **7 DOCUMENTO 7: README Kit Encuesta**

**Archivo:** readme\_kit\_encuesta\_es.md

**Tamaño:** ~20 páginas

**Propósito:** Quick-start guide, FAQ, troubleshooting

### *Contenido:*

- Overview: Qué contiene kit, tamaños, formato
- Quick Start (5 pasos):
- Download (5 min)
- Preparación (30 min)
- Assessment (3-5 weeks)
- Presentación (1-2 weeks)
- Implementación (6-18 months)
- Cómo usar cada documento: Cuándo, cómo, preguntas típicas
- FAQ (15 preguntas comunes):
- Timeline (3-5 weeks)
- Consultant requirement (optional)
- Low scores (normal)
- IMC vs audit
- Phasing (no simultáneo)
- ROI (realistic 180%)
- NIS2 timeline (11 meses)
- Escalado múltiples ubicaciones
- Integración ISO 27001
- Stakeholder engagement
- Post-assessment roadmap
- Risk if no action
- Alternativas frameworks
- etc.
- Troubleshooting (5 problemas comunes):

- Divergent stakeholder responses
- Excel formula errors
- Budget rejection
- NIS2 deadline urgency
- Missing tools/systems

- Referencias: Documentos regulatorios, herramientas, consultores
- Checklist: 10 items pre-kick
- Próximos pasos: Weekly timeline

Implementación (6-18 months)

**Cómo usar cada documento:** Cuándo, cómo, preguntas típicas

etc.

**Troubleshooting (5 problemas comunes):**

Missing tools/systems

**Referencias:** Documentos regulatorios, herramientas, consultores

*Quién lo usa:*

- Everyone: First read (15 min familiarization)
- Project Lead: Ejecutar 5 pasos, timeline management
- Finance/Leadership: FAQ (budgets, timeline, ROI)
- Support: Troubleshooting cuando surge problemas

*Cuándo se usa:*

- Day 0: Todos leen README (30 min)
- Weekly: Consultar cuando surge pregunta/issue
- Ongoing: Reference guide durante assessment & implementation

## FLUJO INTEGRADO: CÓMO TRABAJAN JUNTOS LOS 7 DOCUMENTOS

### SEMANA 0: PRE-KICK (Leer/Preparación)

- Doc #3 (Narrativa): CISO + board leen contexto (15 min)
- Doc #7 (README): Everyone familiarización (30 min)
- Doc #2 (Guía): Facilitador training (2 hours)

### SEMANA 1: ASSESSMENT EXECUTION

- Doc #1 (Encuesta): Cuestionario usado durante 5 interviews
- Doc #2 (Guía): Referencia scoring criteria durante interviews
- Doc #7 (README): Consulta FAQ para aclaraciones
- Recolecta: 51 respuestas × 5 stakeholders = 255 data points

### SEMANA 2-3: ANÁLISIS & CONSOLIDACIÓN

- Doc #5 (Excel): Entra respuestas → calcula IMC automáticamente
- Doc #4 (Mapeo): Valida vs regulaciones → identifica gaps NIS2/ISO
- Doc #2 (Guía): Referencia para resolver divergencias
- Salida: IMC score, compliance %, gaps normativo

### SEMANA 4: REPORTE & PRESENTACIÓN

- Doc #6 (PowerPoint): Customiza template con tu data
- Doc #5 (Excel): Extrae visualizaciones para slides
- Doc #4 (Mapeo): Incorpora findings normativos
- Doc #7 (README): Consulta FAQ de stakeholders
- Ensayo: Mock presentation interna (30 min)

### SEMANA 5: BOARD DECISION

- Doc #6 (PowerPoint): Presenta a board (45 min)
- Doc #5 (Excel): Hand-out financiero (budget printout)
- Recolecta: 5 decisiones de aprobación
- Siguiente: Implementación roadmap (18 months)

### MONTHLY TRACKING (Months 2-18):

- Doc #5 (Excel): Update monthly con nuevos datos
- Doc #7 (README): Consulta FAQ/troubleshooting
- Doc #6 (PowerPoint): Quarterly board updates (adaptar template)
- Progreso: Track IMC trajectory 39 → 78 (target end-2026)

## PRESUPUESTO INTEGRADO

| Fase               | Docs Usados | Inversión                    | Timeline   | IMC Target  |
|--------------------|-------------|------------------------------|------------|-------------|
| 0 - Assessment     | 1,2,3,6,7   | €10-15K<br>(consultant, opt) | 5 weeks    | 39 baseline |
| 1 - Foundation     | 1,3,4,5,7   | €0 (interno)                 | 1 month    | 39→45       |
| 2 - Core Technical | 1,4,5,6     | €1.2M                        | 2-3 months | 45→65       |
| 3 - Compliance     | 4,5         | €200K                        | 1-2 months | 65→72       |
| 4 - Advanced       | 5,6         | €700K                        | 9+ months  | 72→85+      |
| TOTAL 2026         | All 7       | €2.1M                        | 18 months  | 39→78       |

## INDICADORES CLAVE INTEGRADOS

| Métrica              | Current | Target 2026 | Target 2027 | Doc Ref |
|----------------------|---------|-------------|-------------|---------|
| IMC Global           | 39      | 78 (L3-4)   | 85+ (L4+)   | 5,6,7   |
| NIS2 Readiness       | 72%     | 95%+ ✓✓     | 98%+        | 4,5,6   |
| ISO 27001 Readiness  | 68%     | 95%+        | 98%+        | 4       |
| MTTD (Incident)      | 50 días | <24 horas   | <12 horas   | 1,2,5   |
| MTTR (Critical Vuln) | 22 días | <5 días     | <3 días     | 1,2,5   |
| Phishing Click-Rate  | 28%     | <8%         | <3%         | 1,5     |
| SIEM Operational     | No      | Yes         | Enhanced    | 1,5,6   |
| MFA Coverage         | 60%     | 100%        | 100%        | 1,5     |
| PAM Deployed         | No      | Pilot       | Operational | 1,5     |
| Strategy Documented  | Parcial | Formal      | Integrated  | 1,3,7   |

## ✓ CHECKLIST INTEGRACIÓN 7 DOCUMENTOS

### Pre-Assessment:

- [ ] Download & review todos 7 documentos (2 horas)
- [ ] CISO + leadership lee Doc #3 (Narrativa) - 15 min
- [ ] Project team lee Doc #7 (README) - 30 min
- [ ] Facilitador studies Doc #2 (Guía) - 2 hours
- [ ] Designar roles & responsabilidades
- [ ] Schedule 5 interviews Week 1

### During Assessment:

- [ ] Usar Doc #1 (Encuesta) como cuestionario estructura
- [ ] Referencia Doc #2 (Guía) para scoring criteria
- [ ] Consulta Doc #7 (README) para FAQ aclaraciones

### Post-Assessment:

- [ ] Entrar datos en Doc #5 (Excel) → calcula IMC
- [ ] Validar contra Doc #4 (Mapeo Normativo)
- [ ] Customizar Doc #6 (PowerPoint) con tu data
- [ ] Consulta Doc #7 (README) para presentation tips
- [ ] Ensayar presentación (30 min)

### Presentation & Beyond:

- [ ] Presentar Doc #6 (PowerPoint) a board
- [ ] Distribuir Doc #5 (Excel) como handout
- [ ] Recolectar aprobaciones (5 decisiones)

- [ ] Iniciar implementación roadmap
- [ ] Monthly tracking con Doc #5 (Excel)
- [ ] Quarterly board updates (Doc #6 adaptado)
- [ ] Referencia continua Doc #7 (README) para Q&A

## 🏁 CONCLUSIÓN: KIT COMO SISTEMA INTEGRADO

Los 7 documentos funcionan como **sistema cohesivo e interdependiente**, no como piezas sueltas:

| Doc                 | Rol en Sistema                               |
|---------------------|----------------------------------------------|
| 1 - Encuesta        | Cuestionario operacional (input)             |
| 2 - Guía            | Scoring rigor (validación)                   |
| 3 - Narrativa       | Contexto estratégico (justificación)         |
| 4 - Mapeo Normativo | Compliance validation (alineación)           |
| 5 - Excel           | Cálculos & financiero (output analítico)     |
| 6 - PowerPoint      | Comunicación ejecutiva (output) Presentation |
| 7 - README          | Soporte & operacional (guía práctica)        |

### Valor Total:

- 240 páginas de contenido profesional exhaustivo
- Metodología rigurosa (GQM + 5-level maturity)
- Compliance completo (NIS2, ISO, GDPR, Plan Nacional)
- Business case cuantificado (€2.1M, 180% ROI, 10-month payback)
- Presentación board-ready + decisiones ejecutivas
- Roadmap 18 meses con fases claras
- Soporte operacional (FAQ, troubleshooting, templates)

### FIN DE SÍNTESIS EJECUTIVA

*Kit Completo: 7 documentos profesionales | ~240 páginas | Listo para implementación inmediata*